

INF44 GESTIÓN DE LA SEGURIDAD

LECCIÓN 03: TIPOS Y CONTROLES CRÍTICOS DE SEGURIDAD

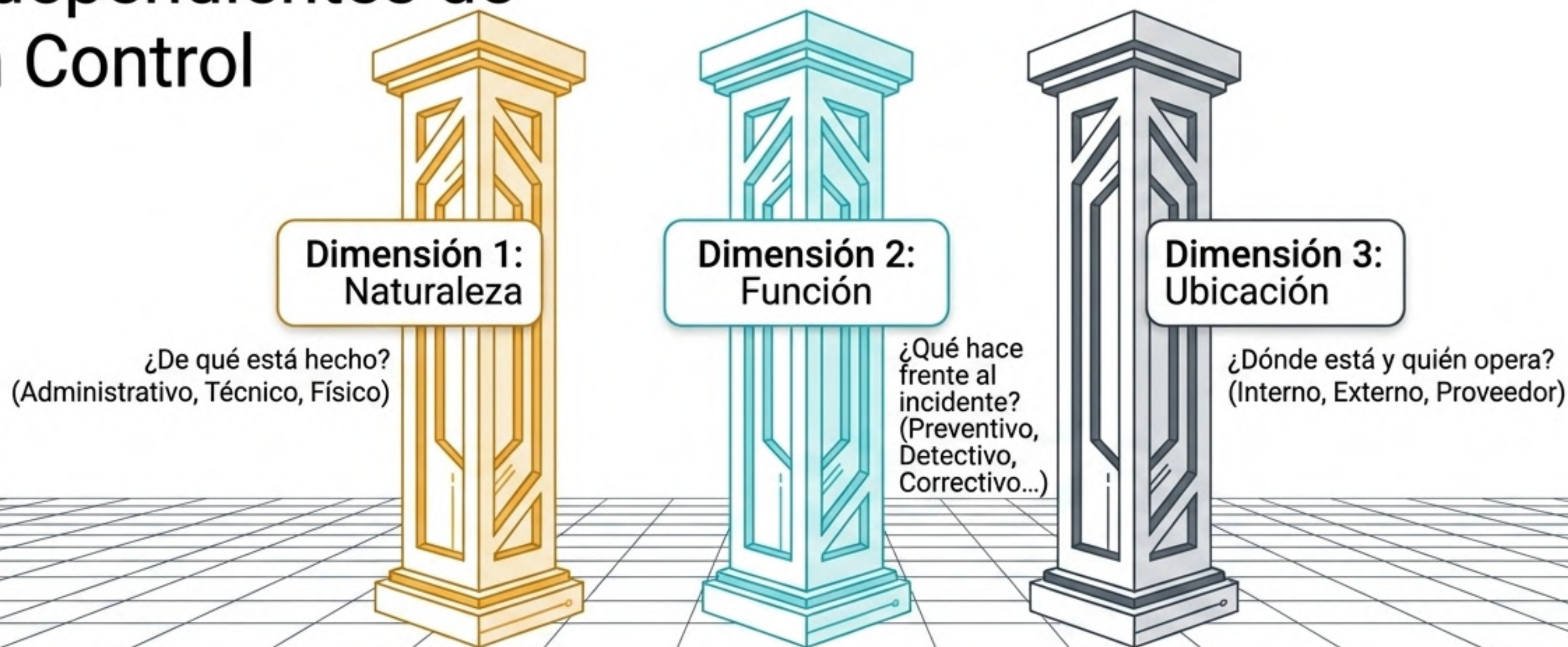
PROPÓSITO DE LA LECCIÓN:

Entregar las herramientas conceptuales y metodológicas para transformar riesgos abstractos en defensas verificables, medibles y alineadas a estándares internacionales (CIS v8.1, NIST, OWASP).

Del escenario al control: ruta de análisis



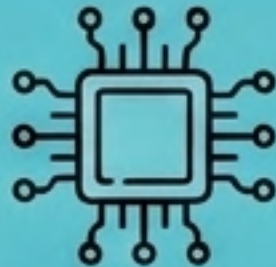
Tres Dimensiones Independientes de un Control



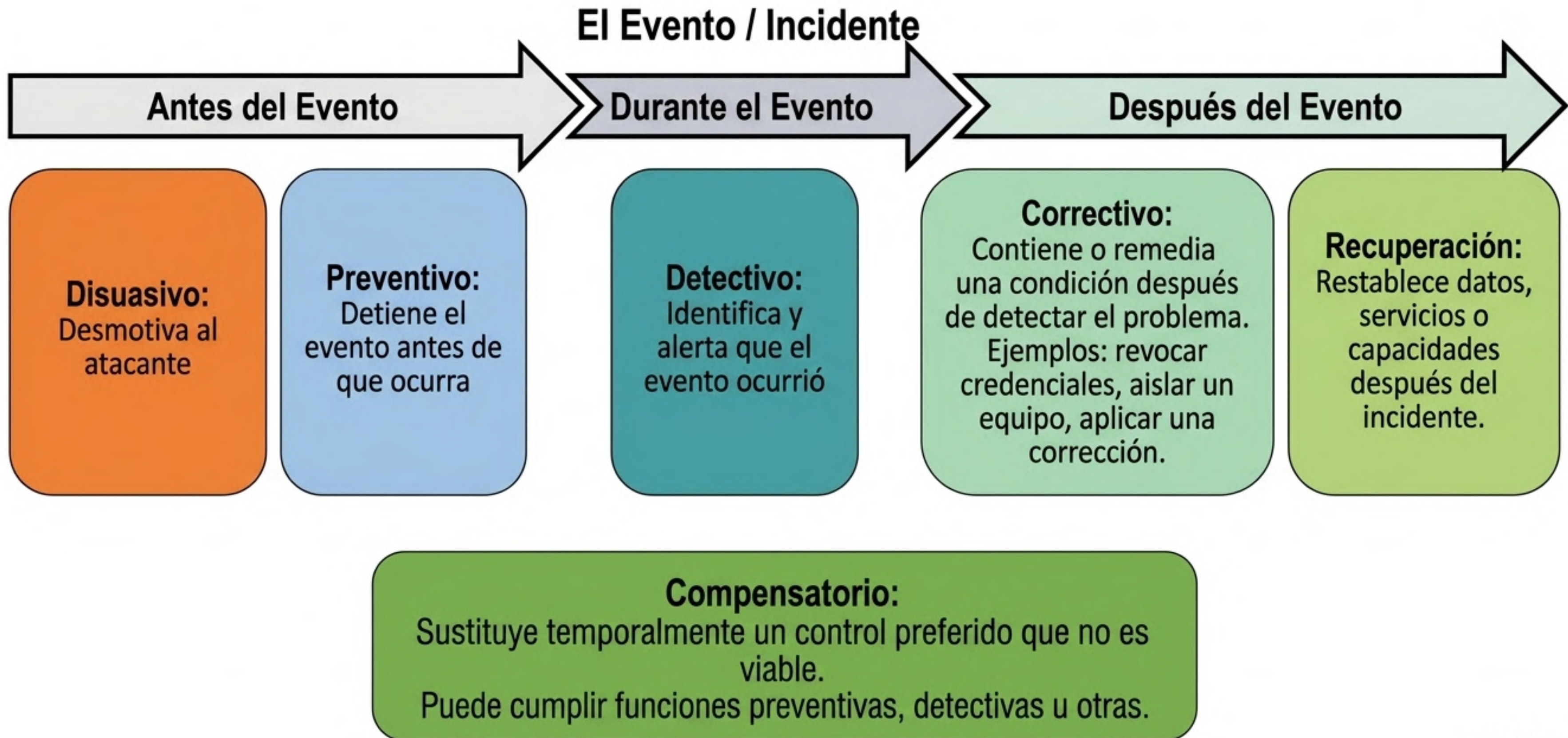
Regla Crítica: No mezcles dimensiones. Un candado de seguridad es Físico (Naturaleza), pero al mismo tiempo es Preventivo (Función).

Dimensión 1:

Naturaleza del Control

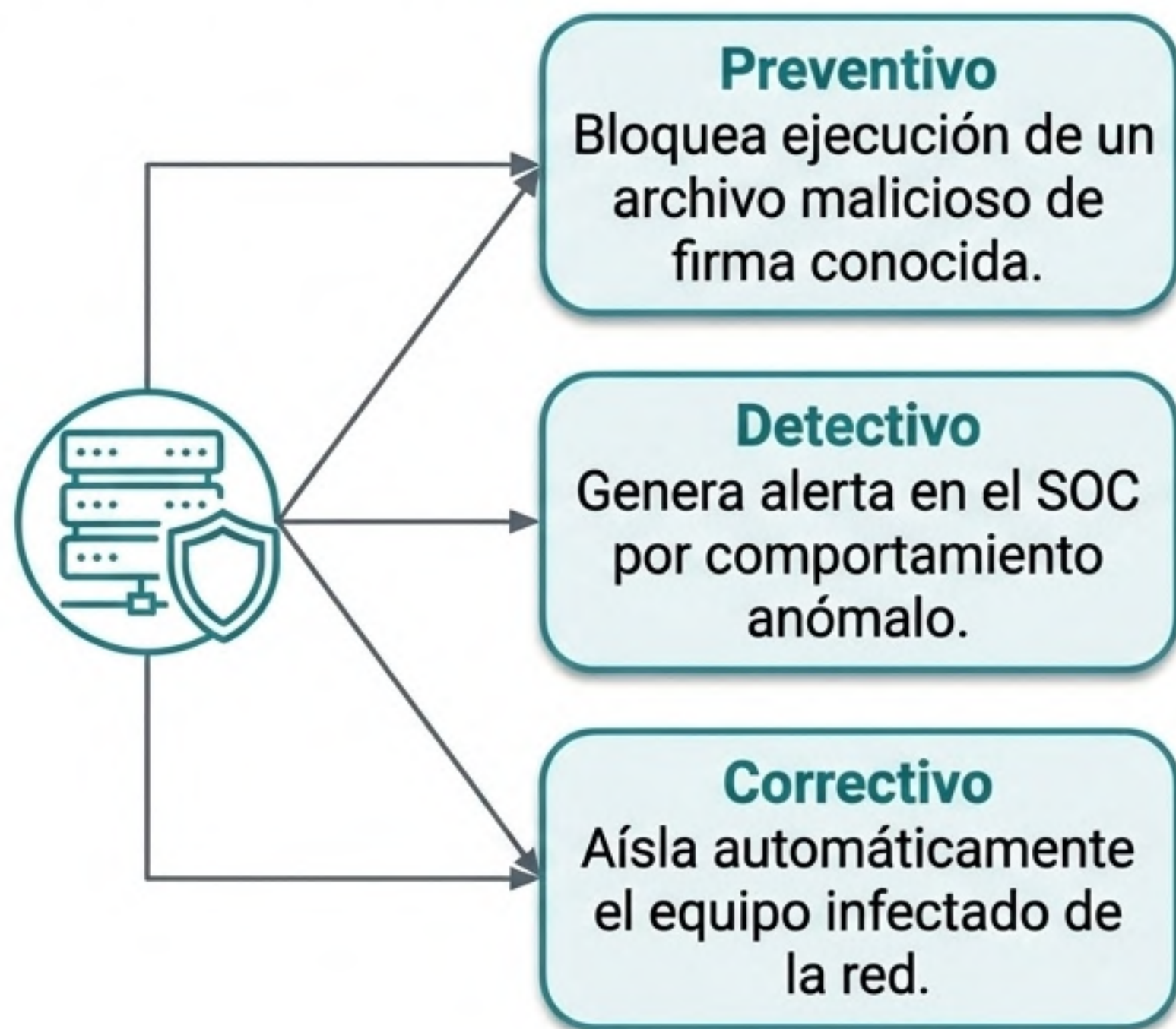
 Administrativo (Políticas)	 Técnico Sistemas y configuraciones lógicas	 Físico (Tangible)
Mecanismo: Guía y restringe el comportamiento humano.	Mecanismo: Automatiza restricciones, permisos y monitoreo.	Mecanismo: Restringe el acceso material al activo.
Ejemplos: Política de uso aceptable, capacitaciones anti-phishing.	Ejemplos: EDR, MFA, reglas de Firewall.	Ejemplos: Molinetes, cerraduras, cámaras de seguridad.
Evidencia: Documentos firmados, registros de asistencia, pruebas.	Evidencia: Capturas de configuración, logs, reportes del sistema.	Evidencia: Inspección visual en terreno, bitácoras de guardias.

Dimensión 2: Función del Control en el Tiempo



Un Control, Múltiples Funciones

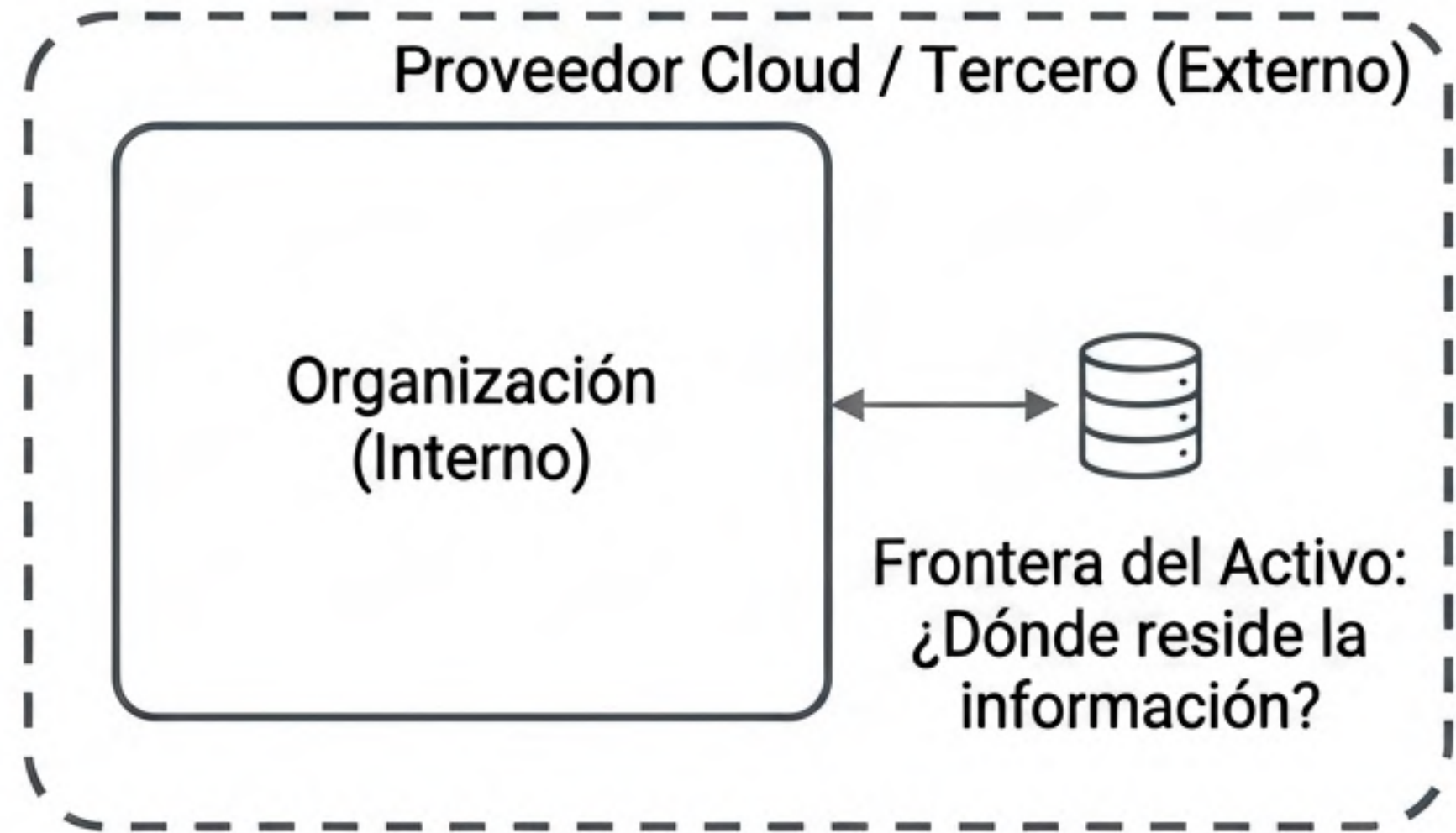
Cada etiqueta funcional debe justificarse por el mecanismo exacto que produce el resultado.



Dimensión 3: Ubicación, Operador y Fronteras

Ubicación vs. Operador

- **Ubicación:** Dónde se ejecuta física/lógicamente el control (On-premise vs. Nube).
- **Operador:** Quién administra el control (Personal propio vs. Tercero/MSSP).



Responsabilidad frente a Proveedores (Ej: Correo Cloud/SaaS)

Externalizar un control no elimina la responsabilidad de la organización de gestionar el riesgo. Debe definir requisitos, revisar evidencia, supervisar al proveedor y gestionar el riesgo residual. Requiere validación mediante auditorías, contratos y SLA.

Ciclo de Vida: El mito de la "Herramienta Instalada"

Tener una **política escrita** (Existencia) o una **herramienta instalada** (Implementación) **NO** demuestra Efectividad. Solo la evaluación mediante **pruebas** lo hace.



Evidencia y Evaluación del Control

Métodos de Evaluación (Pruebas no disruptivas)



Examinar: Revisar configuraciones, logs, tickets. (Evidencia documental).



Entrevistar: Consultar a operadores. (Requiere verificación cruzada).



Probar: Simular una condición de forma controlada. (Ej: Intentar salto de red desde Wi-Fi de invitados).

Métricas para demostrar Efectividad



Cobertura: ¿Protege al 100% de los activos críticos declarados?



Oportunidad: ¿Detecta y alerta antes de que el impacto sea irreversible?



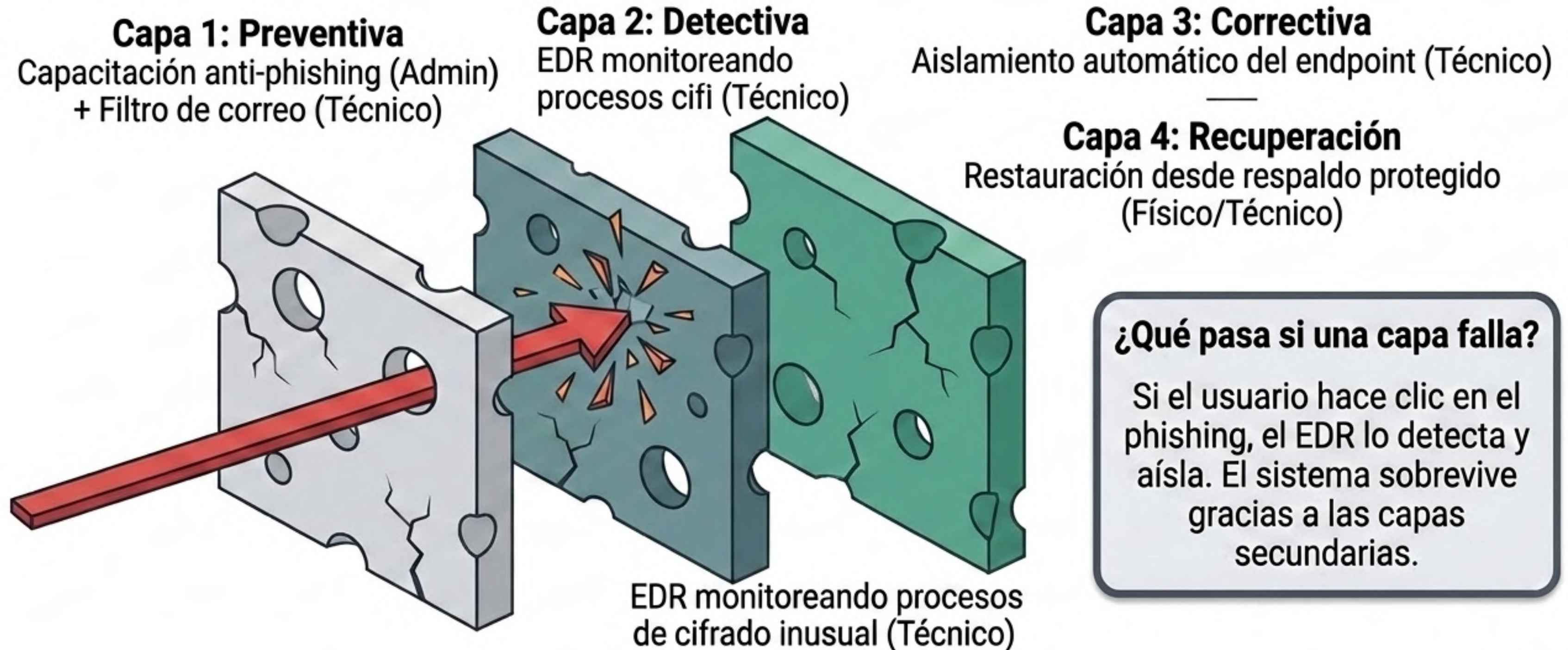
Calidad: ¿Falla frecuentemente o satura con falsos positivos?



Resultado: ¿Se logró empíricamente el Objetivo de Control?

Defensa en Profundidad (Capas Complementarias)

Ningún control es infalible. Combinamos Naturaleza y Función para cubrir todo el ciclo del incidente.



CIS Controls v8.1: Controles priorizados de ciberseguridad

Un conjunto priorizado de 18 controles de ciberseguridad diseñados para reducir los riesgos y ataques más comunes.



En esta asignatura utilizaremos CIS Controls v8.1, compuesto por 18 controles. La referencia a 27 controles del programa 2022 se conserva solo como antecedente histórico.

1. Inventario Activos	2. Inventario Software	3. Protección Datos
4. Configuración Segura	5. Gestión Cuentas	6. Control Accesos
7. Gestión Vulnerabilidades	8. Logs de Auditoría	9. Navegadores/Correo
10. Defensas Malware	11. Recuperación Datos	12. Infraestructura Red
13. Monitoreo Red	14. Concientización	15. Proveedores
16. Software App	17. Respuesta Incidentes	18. Pruebas Penetración

Grupos de Implementación (IG) y Dependencias



Dependencias Lógicas (Secuencia)

Esenario 1: Inventario antes de Proteger: No puedes asegurar lo que no ves (CIS 1 & 2 -> CIS 4).



Esenario 2: Cuentas antes de Accesos: Identificar usuarios antes de gestionar privilegios (CIS 5 -> CIS 6).



Esenario 3: Logs antes de Monitorear: Generar registros antes de analizar tráfico (CIS 8 -> CIS 13).



Esenario 4: Respaldos antes de recuperar: implementar y probar recuperación de datos (CIS 11).

Desarrollo Seguro y Terceros (CIS 15 y 16)

CIS 15: Gestión de Proveedores

Externalizar un servicio no elimina el riesgo. La organización debe definir requisitos, solicitar evidencia, supervisar al proveedor y gestionar incumplimientos.

Ejemplo: Monitorear continuamente las dependencias y accesos de un proveedor web externo.

CIS 16: Seguridad en Software

Integrar seguridad desde el diseño, revisión de cambios, control de versiones y pruebas de seguridad (por ejemplo, SAST y DAST).

Estándares de Referencia

OWASP ASVS: Estándar de Verificación de Seguridad de Aplicaciones (Define qué probar y el rigor técnico).

NIST SSDF: Secure Software Development Framework (Marco de procesos para mitigar vulnerabilidades).

Priorización Operativa a 30 / 90 / 180 Días

Ejemplo de hoja de ruta. Los plazos dependen de exposición, dependencias y capacidad; no son reglas fijas.

Criterios de Ordenamiento

Exposición crítica, Dependencia lógica (Controles base primero), Capacidad (Quick Wins a 30 días).

30 DÍAS — Visibilidad y exposición inmediata.



Acción: Completar inventario crítico y habilitar MFA en cuentas administrativas compatibles.

Por qué primero: Otros controles dependen de conocer activos y cuentas.

Evidencia: Inventario actualizado y cobertura MFA.

Métrica: % de activos inventariados y cuentas protegidas.

90 DÍAS — Consolidar controles.



Acción: Validar la segmentación de redes y asignar responsable a la revisión de alertas.

Dependencia: Requiere activos, responsables y flujos previamente identificados.

Evidencia: Diagrama, prueba controlada y registros de revisión.

Métrica: % de alertas revisadas dentro del plazo definido.

180 DÍAS — Madurez y validación.



Acción: Probar recuperación y fortalecer requisitos de seguridad de proveedores.

Objetivo: Verificar que los controles funcionan y no solo existen.

Evidencia: Resultado de restauración y evidencia técnica del proveedor.

Métrica: Restauraciones exitosas y % de cambios con evidencia de seguridad.

Síntesis Operativa: Método Paso a Paso

1 Contexto del Riesgo Identificar Activo + Condición + Consecuencia.	2 Objetivo Verificable ¿Qué estado seguro queremos lograr y medir?	3 Definición del Control Describir la solución exacta (Ej: EDR, segmentación).	4 Clasificación Naturaleza + Función + Ubicación/Operador.
5 Evaluación ¿Cómo pruebo su efectividad sin romper la operación?	6 Defensa en Profundidad ¿Qué otra capa compensa si este falla?	7 Alineación CIS ¿A cuál de los 18 controles (v8.1) corresponde?	8 Priorización ¿Va a 30, 90 o 180 días basado en dependencias?

La seguridad no es una herramienta instalada, es una condición demostrable.